

CYROPAY LTD

Access Control Policy

Document Classification: Internal
Document ID: POL-003
Version: 1.0
Policy Owner: Chief Information Security Officer (CISO)
Approved By: Chief Executive Officer (CEO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

1. Purpose

This Access Control Policy establishes the requirements for managing access to CyroPay Ltd’s information systems, applications, data, and physical environments. It ensures that access to information assets is granted based on business need, follows the principle of least privilege, and is subject to appropriate authorisation and review.

2. Scope

This policy applies to:

- All employees, contractors, consultants, and third-party users requiring access to CyroPay systems.
- All CyroPay-managed systems, applications, APIs, cloud environments, and databases.
- All physical access to CyroPay premises and secure areas.
- All privileged, administrative, and service accounts.

3. Definitions

Term	Definition
------	------------

Least Privilege	Granting users only the minimum access rights necessary for their role
Privileged Access	Elevated access rights allowing administrative, system, or configuration changes
IAM	Identity and Access Management
MFA	Multi-Factor Authentication
Role-Based Access Control (RBAC)	Access rights assigned based on job role rather than individual
Access Review	Periodic validation that access rights remain appropriate
Stale Account	A user account that has not been used within a defined period

4. Roles and Responsibilities

4.1 CISO

1. Owns and maintains this policy.
2. Oversees access governance and ensures access reviews are conducted.
3. Approves exceptions and privileged access requests.

4.2 IT and Engineering Teams

1. Implement access controls in line with this policy.
2. Provision and de-provision user accounts on instruction.
3. Maintain IAM configurations and audit logs.

4.3 Line Managers

1. Initiate access requests for their teams.
2. Approve access rights for direct reports.
3. Notify IT promptly upon employee departure or role change.

4.4 All Users

1. Use only accounts and access rights assigned to them.

2. Report suspected unauthorised access or anomalous activity immediately.
 3. Not share credentials or access tokens under any circumstances.
-

5. Policy Requirements

5.1 Access Provisioning

1. All access requests must be submitted through the formal IT ticketing process.
2. Access must be approved by the relevant line manager and the Information Security team for sensitive systems.
3. Access rights must follow the principle of least privilege and be role-based where possible.
4. New starters must have access provisioned only after completion of onboarding processes including security awareness training.
5. Temporary access must include a defined expiration date.

5.2 Access De-provisioning

1. Access must be revoked on the employee's last working day or immediately upon termination.
2. HR must notify IT and the Information Security team no later than the day of departure.
3. Contractor and third-party access must be revoked immediately upon contract termination.
4. Stale accounts inactive for 90 days must be disabled and reviewed.

5.3 Privileged Access

1. Privileged access must be restricted to named individuals with a documented business justification.
2. Privileged accounts must not be used for routine day-to-day activities.
3. All privileged actions must be logged and subject to audit review.
4. Shared administrative accounts are prohibited unless formally risk assessed and approved by the CISO.
5. Privileged access must be reviewed at minimum every 90 days.

5.4 Multi-Factor Authentication

1. MFA must be enforced for all privileged access, VPN connections, cloud administration consoles, and remote access services.
2. MFA must be enforced for access to finance, HR, and sensitive data systems.
3. Exemptions to MFA requirements must be approved by the CISO and compensating controls applied.

5.5 Access Reviews

1. Access rights for all users must be formally reviewed at minimum every six months.
2. Privileged access must be reviewed every 90 days.
3. Access reviews must be documented and results retained as evidence of compliance.
4. Inappropriate or excess access identified during review must be remediated within 14 days.

5.6 Third-Party Access

1. Third-party access must be subject to a formal request, approval, and review process.
2. Third parties must access CyroPay systems only through approved, audited connection methods.
3. Just-in-time access controls should be applied where technically feasible.
4. Third-party access must be reviewed quarterly.

5.7 Physical Access

1. Access to CyroPay premises and secure areas must be controlled through appropriate physical controls.
 2. Visitor access must be logged and supervised.
 3. Physical access rights must be reviewed when employees change roles or leave the organisation.
-

6. Compliance and Monitoring

Access control compliance is monitored through:

1. Periodic access reviews and user account audits.
 2. Privileged account monitoring and SIEM alerting.
 3. Review of IAM logs during incident investigations.
 4. Annual internal audits of the access control framework.
-

7. Exceptions

Exceptions must be formally documented, risk assessed, approved by the CISO, and reviewed periodically. Temporary exceptions must include an expiration date.

8. Related Documents

1. POL-001 Information Security Policy
 2. POL-004 Password and Authentication Policy
 3. POL-008 Third-Party Security Policy
 4. POL-009 Remote Working Policy
-

9. ISO/IEC 27001:2022 Annex A Mapping

Annex A Control	Description
A.5.15	Access control
A.5.16	Identity management
A.5.17	Authentication information
A.5.18	Access rights
A.6.1	Screening
A.8.2	Privileged access rights
A.8.3	Information access restriction
A.8.5	Secure authentication

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version